

Cyber Security Trainee assignment

SCAN PROCESS OUT PUT

WHOIS & DIG

```
[root@parrot]~#dig +nocmd itsecgames.com any +noall +answer | tee dig-any.txt
itsecgames.com.      600    IN      A        31.3.96.40
itsecgames.com.      3600   IN      NS       ns54.domaincontrol.com.
itsecgames.com.      3600   IN      NS       ns53.domaincontrol.com.
itsecgames.com.      3600   IN      SOA      ns53.domaincontrol.com. dns.jomax.net. 2025011303 28800 7200 604800 600
itsecgames.com.      3600   IN      MX       5 itsecgames-com.mail.protection.outlook.com.
itsecgames.com.      3600   IN      TXT      "v=spf1 mx a include:spf.protection.outlook.com include:servers.mcsv.net include:mme-srv-dc1.mme.local -all"
```

```
[root@parrot]~#whois itsecgames.com | tee whois.txt
Domain Name: ITSECGAMES.COM
Registry Domain ID: 1721761149_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.godaddy.com
Registrar URL: http://www.godaddy.com
Updated Date: 2025-05-22T10:55:31Z
Creation Date: 2012-05-21T13:35:16Z
Registry Expiry Date: 2027-05-21T13:35:16Z
Registrar: GoDaddy.com, LLC
Registrar IANA ID: 146
Registrar Abuse Contact Email: abuse@godaddy.com
Registrar Abuse Contact Phone: 480-624-2505
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Domain Status: clientRenewProhibited https://icann.org/epp#clientRenewProhibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Name Server: NS53.DOMAINCONTROL.COM
Name Server: NS54.DOMAINCONTROL.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>> Last update of whois database: 2025-09-25T16:05:09Z <<<
```

HTTP headers + homepage:

```
curl -sI http://www.itsecgames.com/ | tee headers_http.txt
```

HTTP/1.1 200 OK

Date: Fri, 26 Sep 2025 14:39:37 GMT

Server: Apache

Last-Modified: Wed, 09 Feb 2022 13:14:08 GMT

ETag: "e43-5d7959bd3c800"

Accept-Ranges: bytes

Content-Length: 3651

Vary: Accept-Encoding

Content-Type: text/html

```
curl -sL http://www.itsecgames.com/ -o homepage_http.html
```

<!DOCTYPE html>

<html>

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8">

<link rel="stylesheet" type="text/css" href="https://fonts.googleapis.com/css?family=Architects+Daughter">

<link rel="stylesheet" type="text/css" href="stylesheets/style.css" media="screen" />

<link rel="shortcut icon" href="images/favicon.ico" type="image/x-icon" />

<!--<script src="//html5shiv.googlecode.com/svn/trunk/html5.js"></script>-->

<script src="js/html5.js"></script>

<title>bWAPP, a buggy web application!</title>

</head>

<body>

<header>

<h1>bWAPP</h1>

<h2>an extremely buggy web app !</h2>

</header>

<div id="menu">

<table>

<tr>

<td>Home</td>

<td>Bugs</td>

<td>Download</td>

<td>Talks & Training</td>

<td>Blog</td>

</tr>

</table>

</div>

<div id="main">

<h1>Home</h1>

<p>bWAPP, or a <i>buggy web application</i>, is a free and open source deliberately insecure web application.

It helps security enthusiasts, developers and students to discover and to prevent web vulnerabilities.

bWAPP prepares one to conduct successful penetration testing and ethical hacking projects.</p>

<p>What makes bWAPP so unique? Well, it has over 100 web vulnerabilities!

It covers all major known web bugs, including all risks from the OWASP Top 10 project.</p>

<p>bWAPP is a PHP application that uses a MySQL database. It can be hosted on Linux/Windows with Apache/IIS and MySQL.

It can also be installed with WAMP or XAMPP.

Another possibility is to download the <i>bee-box</i>, a custom Linux VM pre-installed with bWAPP.</p>

<p>Download our What is bWAPP? introduction tutorial, including free exercises...</p>

<p>bWAPP is for web application security-testing and educational purposes only.

Have fun with this free and open source project!</p>

<p>Cheers, Malik Mesellem</p>

</div>

<div id="sponsor">

<table>

<tr>

```

                <td align="center"><a href="https://www.mmesec.com" target="_blank"></a>&nbsp;&nbsp;&nbsp;</td>
                <td>&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;</td>
                <td align="center"><a href="https://www.owasp.org" target="_blank"></a></td>
            </tr>
        </table>
    </div>
    <div id="side">
        <a href="https://twitter.com/MME_IT" target="blank_" class="button"></a>
        <a href="https://be.linkedin.com/in/malikmesellem" target="blank_" class="button"></a>
        <a href="https://www.facebook.com/mmebv/" target="blank_" class="button"></a>
        <a href="https://itsecgames.blogspot.com" target="blank_" class="button"></a>
    </div>
    <div id="disclaimer">
        <p>bWAPP is licensed under <a rel="license" href="http://creativecommons.org/licenses/by-nc-nd/4.0/"
target="_blank"></a> &copy; 2022 MME BV / Follow <a
href="https://twitter.com/MME_IT" target="_blank">@MME_IT</a> on Twitter and ask for our cheat sheet, containing all
solutions! / Need an exclusive <a href="https://www.mmesec.com/training" target="blank_">training</a>?</p>
    </div>
    <div id="bee">
        
    </div>

</body>

</html>

```

Tech fingerprint:

```
openssl s_client -connect www.itsecgames.com:443 -servername www.itsecgames.com </dev/null 2>/dev/null | sed -n
'1,240p' > openssl.txt || true
```

```

CONNECTED(00000003)
---
Certificate chain
0 s:CN = web.mmebvba.com
i:CN = web.mmebvba.com
a:PKKEY: rsaEncryption, 2048 (bit); sigalg: RSA-SHA256
v:NotBefore: May 25 09:07:54 2015 GMT; NotAfter: May 22 09:07:54 2025 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIICxGCCAaygAwIBAgIJALpeeeDC90PLMA0GCSqGSIb3DQEBCwUAMBoxGDAWBgNV
BAMMD3dIYi5tbWVidmJhLmNvbTAeFw0xNTA1MjUwOTA3NTRaFw0yNTA1MjUwOTA3
NTRaMBoxGDAWBgNVBAMMD3dIYi5tbWVidmJhLmNvbTCCASIwDQYJKoZIhvcNAQEB
BQADggEPADCCAQoCggEBBAK/hFIEmVRyv2fbXel6oUukbiGdpX0Xps5sqis2OxF9Y
/YXJcxaPol/fUyfSdJ6pr2/YoEcUUfZaUIJWbsSz/qzklja0M+GMAVzL+wqAi+V
HjgujqsgeEQxgTiNoQu9Zld5NY7Ac9qQRKbLbLRubQV/9+Dud0Isx3z1gAsJda6
bi3JuL0a27EMztRssKeQCIJhWLAdidjuXH6kc+3jbNPmvedRF+Mw5mk32nNtyZ78
qjIFT7Bny/CNGN31PFgQWq+6pTgCzokui04zV0pYyaGX9hs6roLiQWLT9UqB0wx0
Jr+GM175u2YLvXba+U22cWMOp5IZ359Ohtkf0uuKSzUCAwEAAAMNMAAwCQYDVR0T
BAIwADANBgkqhkiG9w0BAQsFAAOCAQEAgKAHgl1qFsUIDarYKlrjuUxfel2bE1fLd
VGIYBzmaQddzehzBu9Akn9g73DHwrs9+gW9cDfklCIVr3ayzS5KAMhvnZzga1B0+q
NYfX2y61SMnS4w9p8PT3iqZdF/Rywu658BXjpJWojwoA8Hu1mhwTODdSSEofBnlq
azNm62lQsxdTIU7wEanZ0/ExUFNktwKean7Jle3EvH94fkNg2T0er1WuEB/QF6sv
dJqxsYSZ3toPEuqlOryWis0E8pfo3Hauzz6fBGijLcEnMoFp7oCZNz0Xh9Q93aOs
5c9hNmHtQcu3vMrYUYArpj+a/euAEI2HaGJZf5g75mf4gAl/2B7iyg==
-----END CERTIFICATE-----
subject=CN = web.mmebvba.com

```

issuer=CN = web.mmebvba.com

No client certificate CA names sent

Peer signing digest: SHA256

Peer signature type: RSA

Server Temp Key: ECDH, prime256v1, 256 bits

SSL handshake has read 1414 bytes and written 450 bytes

Verification error: certificate has expired

New, TLSv1.2, Cipher is ECDHE-RSA-AES256-GCM-SHA384

Server public key is 2048 bit

Secure Renegotiation IS supported

Compression: NONE

Expansion: NONE

No ALPN negotiated

SSL-Session:

Protocol : TLSv1.2

Cipher : ECDHE-RSA-AES256-GCM-SHA384

Session-ID: DD63F2D40B9BBFC41254F5ACCAA479BCD731D3221D502FA578DA1CC08E877CB0

Session-ID-ctx:

Master-Key:

38D64187658A24C94222595D5637850205497B17709339A96B5BF39FA901FD78550291B1900AFDE5B69FEDE827B7C6ED

PSK identity: None

PSK identity hint: None

SRP username: None

TLS session ticket lifetime hint: 300 (seconds)

TLS session ticket:

0000 - 81 f6 a8 de 88 00 32 b1-a3 d0 0c 78 ec 1b 35 4d2....x..5M
0010 - 39 9a 6e 1f ce b2 cc b2-c7 54 26 4d be 6a 69 28 9.n.....T&M.ji(
0020 - 15 e0 12 e5 62 c5 01 60-cb a9 f6 1d 0f e1 f7 cfb..`.....
0030 - ee a6 de bc 18 0c 2f b0-40 f8 02 31 81 85 1c 33/.@..1...3
0040 - de 63 7d f1 fd 91 e9 8a-08 50 3d ac 03 15 82 c8 .c}.....P=.....
0050 - fd fe b9 91 83 d1 c3 a9-ad 8d 20 53 3a 08 92 bf S:....
0060 - 38 66 c6 9f 0d c1 20 80-3b 81 f1 4a 4f ee 46 76 8f.... ;..JO.Fv
0070 - d8 7c 7a ae 8b 5b 71 d7-37 27 f1 5f d5 3a 96 ac .|z..[q.7'._:..
0080 - 6e ee 01 d1 72 ac f3 45-59 68 0e 68 50 51 0d 3d n...r..EYh.hPQ.=
0090 - 94 a5 b6 46 e8 3c e8 f3-71 ae 41 b3 cb ab bd ef ...F.<..q.A.....
00a0 - 1f 2f f3 b6 9f 30 e8 87-e0 f9 67 34 a6 40 61 22 ./...0....g4.@a"
00b0 - 35 a0 c2 79 1e 77 15 0a-a9 71 7c 92 d8 c1 bd 95 5..y.w...q|.....
00c0 - 48 6a 8f d6 85 0f 1d 1b-fc 02 92 a0 56 99 f2 78 Hj.....V..x

Start Time: 1758905217

Timeout : 7200 (sec)

Verify return code: 10 (certificate has expired)

Extended master secret: no

whatweb -v www.itsecgames.com | tee whatweb.txt

WhatWeb report for <http://www.itsecgames.com>

Status : 200 OK

Title : bWAPP, a buggy web application!

IP : 31.3.96.40

Country : NETHERLANDS, NL

Summary : Apache, HTML5, HTTPServer[Apache], Script

Detected Plugins:

[Apache]

The Apache HTTP Server Project is an effort to develop and maintain an open-source HTTP server for modern operating systems including UNIX and Windows NT. The goal of this project is to provide a secure, efficient and extensible server that provides HTTP services in sync with the current HTTP standards.

Google Dorks: (3)

Website : <http://httpd.apache.org/>

[HTML5]

HTML version 5, detected by the doctype declaration

[HTTPServer]

HTTP server header string. This plugin also attempts to identify the operating system from the server header.

String : Apache (from server string)

[Script]

This plugin detects instances of script HTML elements and returns the script language/type.

HTTP Headers:

HTTP/1.1 200 OK

Date: Fri, 26 Sep 2025 15:05:11 GMT

Server: Apache

Last-Modified: Wed, 09 Feb 2022 13:14:08 GMT

ETag: "e43-5d7959bd3c800-gzip"

Accept-Ranges: bytes

Vary: Accept-Encoding

Content-Encoding: gzip

Content-Length: 1482

Connection: close

Content-Type: text/html

nikto -h http://www.itsecgames.com -o nikto-report.txt

Nikto v2.5.0

+ Multiple IPs found: 31.3.96.40, 64:ff9b::1f03:6028

+ Target IP: 31.3.96.40

+ Target Hostname: www.itsecgames.com

+ Target Port: 80

+ Start Time: 2025-09-26 20:19:31 (GMT5.5)

+ Server: Apache

+ /: The anti-clickjacking X-Frame-Options header is not present. See: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options>

+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: <https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/>

+ No CGI Directories found (use '-C all' to force check all possible dirs)

+ /: Server may leak inodes via ETags, header found with file /, inode: e43, size: 5d7959bd3c800, mtime: gzip. See: <http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418>

+ /wwwitsecgamescom.war: Drupal 7 was identified via the x-generator header. See: https://www.drupal.org/project/remove_http_headers

+ /wwwitsecgamescom.war: Drupal Link header found with value: <<http://31.3.96.40/>>; rel="canonical",<<http://31.3.96.40/>>; rel="shortlink". See: <https://www.drupal.org/>

+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS .

+ /icons/README: Apache default file found. See: <https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/>

+ 8077 requests: 0 error(s) and 7 item(s) reported on remote host

+ End Time: 2025-09-26 21:07:59 (GMT5.5) (2908 seconds)

+ 1 host(s) tested

nmap -sS -sV --top-ports 200 -oA nmap-top 31.3.96.40

Starting Nmap 7.94SVN (<https://nmap.org>) at 2025-09-26 21:23 IST

Nmap scan report for web.mmebvba.com (31.3.96.40)

Host is up (0.068s latency).

Not shown: 197 filtered tcp ports (no-response)

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 6.7p1 (protocol 2.0)

80/tcp open http Apache httpd

443/tcp open ssl/http Apache httpd

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 26.02 seconds

Executive summary

Passive and light active reconnaissance of <http://www.itsecgames.com> (IP **31.3.96.40**) shows the site is hosting **bWAPP** — an intentionally vulnerable web application for training. Because bWAPP purposely contains many OWASP Top 10 bugs, **public exposure is a high risk** if this instance is not isolated. Additional findings from DNS, HTTP headers, Nikto and Nmap include an SPF misconfiguration that leaks an internal host (`mme-srv-dc1.mme.local`), missing security headers (`X-Frame-Options`, `X-Content-Type-Options`), ETag inode leakage, Drupal-related headers on a suspicious path, and open services including SSH (OpenSSH 6.7p1) and HTTPS. Below are detailed findings arranged by your objectives, with evidence, impact, prioritization and remediation.

Objective 1 — Identify vulnerabilities on this domain (tool-reported evidence)

A — Nikto findings (tool: Nikto v2.5.0)

Evidence (quoting Nikto output):

- + /: The anti-clickjacking X-Frame-Options header is not present.
- + /: The X-Content-Type-Options header is not set.
- + /: Server may leak inodes via ETags, header found with file /, inode: e43, size: 5d7959bd3c800, mtime: gzip.
- + /wwwitsecgamescom.war: Drupal 7 was identified via the x-generator header.
- + OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS .
- + /icons/README: Apache default file found.

Interpretation: Nikto reported multiple configuration issues and potential information leaks (missing headers, ETag inode leak). It also found a path that advertises Drupal 7 (which may be unrelated content or stale header) and default Apache content `/icons/README`.

Impact: Missing hardening headers and ETag leaks increase the chance of browser-based attacks (clickjacking, MIME-sniffing) and aid attackers mapping the stack. If Drupal 7 is actually in use anywhere, it may be an outdated component with known CVEs.

Severity: Medium.

Remediation (short):

- Add `X-Frame-Options: DENY` (or `SAMEORIGIN`) and `X-Content-Type-Options: nosniff`.
- Remove ETag-based inode leakage (disable `FileETag` or configure `FileETag None` in Apache).
- Remove default Apache files (`icons/README`) from public webroot.
- Investigate the `/wwwitsecgamescom.war` endpoint and remove or secure any outdated Drupal instances.

Validation: Re-run Nikto and confirm the listed items are no longer present.

B — Nmap service discovery (tool: nmap)

Evidence (quoting nmap output):

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.7p1 (protocol 2.0)
80/tcp    open  http     Apache httpd
443/tcp   open  ssl/http Apache httpd
```

Interpretation: Host exposes SSH (OpenSSH 6.7p1), HTTP and HTTPS (Apache). OpenSSH 6.7p1 is an older release (review for known CVEs). Presence of port 22 and service versions increases attack surface.

Impact: Unpatched/old OpenSSH or Apache versions can contain public CVEs that allow remote compromise or privilege escalation. SSH should be restricted to management networks where possible.

Severity: Medium → High depending on exposed service versions & patch level.

Remediation:

Restrict SSH (port 22) to authorized admin IPs (firewall/iptables). Consider key-based auth only and disable password auth.

Update OpenSSH to latest stable release and apply server OS patches.

Ensure Apache is up-to-date; disable unnecessary modules.

If SSH must be public, enable strong KEX/Cipher settings and monitor logs.

Validation: Re-run targeted `nmap -sV` and verify updated versions / closed port or source IP restrictions.

Objective 2 — Detect potential vulnerabilities (misconfigurations, outdated software, CVEs)

1 — SPF TXT misconfiguration (passive DNS)

Evidence (from dig):

```
"v=spf1 mx a include:spf.protection.outlook.com include:servers.mcsv.net include:mme-srv-dc1.mme.local -all"
```

Interpretation: SPF includes an internal .local host mme-srv-dc1.mme.local that will not resolve externally — indicates misconfiguration and internal naming leakage.

Impact: Information disclosure of internal names; SPF failures causing delivery issues; operational risk. Attackers may use naming conventions to target the internal environment.

Severity: Low → Medium (info-leak + mail trust issues).

Remediation:

Remove include:mme-srv-dc1.mme.local from public SPF record.

Ensure SPF includes only public/authorized sending hosts or IPs.

Validate SPF with an SPF validator (e.g., <https://www.kitterman.com/spf/validate.html>).

Validation: Run `dig txt itsecgames.com` and use an SPF tester.

2 — DNS / WHOIS observations

Evidence (from WHOIS & dig):

A record: itsecgames.com -> 31.3.96.40

Nameservers: NS53.DOMAINCONTROL.COM, NS54.DOMAINCONTROL.COM

WHOIS: Registrar GoDaddy, Domain expiry 2027-05-21

DNSSEC: unsigned

Interpretation & Impact: DNSSEC not enabled — DNS integrity not cryptographically protected, increasing possibility of cache poisoning. Registrar-managed nameservers require account protections.

Severity: Low → Medium.

Remediation: Enable DNSSEC if supported by registrar; ensure registrar account has MFA; set appropriate TTLs and monitor records.

3 — Application intentional vulnerability (bWAPP)

Evidence (homepage HTML title and content):

<title>bWAPP, a buggy web application!</title>

Homepage text: “bWAPP... a deliberately insecure web application... has over 100 web vulnerabilities”

Interpretation: This is an intentionally vulnerable training app. While expected for training, public exposure of such an application is dangerous in production/Internet-facing contexts.

Impact: High — because bWAPP contains many vulnerabilities (SQLi, XSS, RCE, CSRF, etc.) that could be exploited to fully control the host.

Severity: High (for production hosting; if this is a lab, still risky if internet-exposed).

Mitigation:

Remove or restrict bWAPP from internet exposure. Host only in isolated lab networks or behind VPN/authentication.

If public demo is required, use strict network controls: IP allowlisting, VPN, HTTP Basic + HTTPS, rate-limiting, WAF.

Audit logs and monitor for suspicious access.

Validation: Confirm site is not accessible from public Internet or is behind access restrictions.

4 — Header / info leakage (from curl + whatweb)

Evidence:

Server: Apache (header)

Content-Encoding: gzip and ETag: "e43-5d7959bd3c800-gzip" (header)

WhatWeb summary: Apache, HTML5, HTTPServer[Apache], Script

Interpretation: Server banner reveals webserver type; ETag contains inode-ish data (Nikto flagged inode leakage). Banner and headers enable CVE mapping.

Impact: Low → Medium. Revealing product and version details helps attackers craft targeted exploits.

Remediation:

Hide or mask Server header (use ServerTokens Prod and ServerSignature Off in Apache config).

Disable or sanitize ETags (FileETag None).

Add security headers (see below).

Validation: Re-run curl -sI and confirm headers are changed.

Objective 3 — SSL/TLS configuration and certificate health

What we have / what to run

Nmap shows port 443 open (Apache). You provided no complete SSL Labs or openssl output in the files, so do this immediately and attach the report for final grading:

Run SSL Labs test: <https://www.ssllabs.com/ssltest/> (enter www.itsecgames.com) — save the test URL or screenshot.

Locally run:

```
openssl s_client -connect www.itsecgames.com:443 -servername www.itsecgames.com </dev/null  
2>/dev/null | sed -n '1,240p' > openssl.txt  
sslyze --regular www.itsecgames.com > sslyze.txt
```

Attach openssl.txt and (if you ran it) sslyze.txt.

Interim assessment (based on current data):

HTTPS is present; we do not yet have certificate CN/SAN or expiration evidence in provided outputs. Without the SSL Labs or openssl details we cannot conclude grading or weak cipher presence.

Suggested checks and likely remediations:

Ensure certificate is valid, chain complete and not expiring within 30 days. Use Let's Encrypt/CA renewal automation if applicable.

Disable TLS 1.0 / 1.1; support only TLS 1.2 or 1.3.

Disable weak ciphers (RC4, 3DES, EXPORT); prefer AEAD ciphers (AES-GCM, CHACHA20-POLY1305).

Enable HSTS (Strict-Transport-Security), OCSP stapling, and set secure cookie flags.

Validation: Provide SSL Labs grade and openssl output; I'll convert these into findings with exact evidence lines and remediation.

Objective 4 — Exposed information that could aid attackers (headers, banners, error messages)

Consolidated evidence (from curl, Nikto, whatweb, homepage):

Server: Apache

ETag: "e43-5d7959bd3c800-gzip"

HTML reveals bWAPP and links to downloads/vulnerabilities.txt and bWAPP_intro.pdf (explicit listing of vulnerabilities)

robots.txt / sitemap.xml were not provided — please run and attach; they may list admin/test URLs.

Nikto indicates OPTIONS allowed GET, HEAD, POST, OPTIONS (confirm whether unwanted methods can be disabled).

Impact / why it matters:

The site explicitly lists vulnerabilities and provides downloads that describe attack vectors — useful for an attacker.

Missing security headers and server banners make it easier to fingerprint and target specific CVEs.

Default Apache files (icons/README) can leak information and should be removed.

Remediation (short checklist):

Remove or restrict access to all training/vulnerable content unless isolated.

Harden headers: implement Content-Security-Policy, X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Referrer-Policy, Permissions-Policy.

Remove Server/X-Powered-By exposure and default Apache files.

Disable HTTP methods not required (e.g., PUT/DELETE) — verify OPTIONS is not disclosing unwanted methods.

Validation: Re-run curl -I, nikto, and confirm the absence of the previously exposed items.

Objective 5 — Prioritized findings & mitigation recommendations

Below is a prioritized list combining likelihood, impact and current evidence. Each includes remediation and validation.

Priority 1 — High

Finding: Publicly exposed intentionally-vulnerable application (bWAPP).

Why: bWAPP contains many high-risk vulnerabilities (SQLi, RCE, XSS). Public exposure enables easy exploitation.

Evidence: Homepage title and copy: bWAPP, a buggy web application! and link: ./downloads/vulnerabilities.txt.

Mitigation: Immediately restrict access (isolate from Internet). Host only in lab networks or behind VPN/HTTP Basic + IP allowlist and multi-factor admin access. Consider taking the instance offline until secured.

Validation: Ensure homepage is inaccessible from outside or protected by authentication; verify via public curl from external IP.

Priority 2 — Medium / High

Finding: Open SSH with old OpenSSH version (OpenSSH 6.7p1).

Evidence: 22/tcp open ssh OpenSSH 6.7p1 (nmap).

Mitigation: Restrict SSH to admin IPs via firewall; enforce key-based auth; update OpenSSH and OS patches. Review known CVEs for that OpenSSH version and patch accordingly.

Validation: Re-scan and confirm SSH either restricted or updated version.

Priority 3 — Medium

Finding: Missing security headers (X-Frame-Options, X-Content-Type-Options) and ETag inode leakage.

Evidence: Nikto lines: The anti-clickjacking X-Frame-Options header is not present. and The X-Content-Type-Options header is not set. and Server may leak inodes via ETags....

Mitigation: Add X-Frame-Options: DENY/SAMEORIGIN, X-Content-Type-Options: nosniff. Set FileETag None. Implement CSP.

Validation: curl -sI return shows headers present and ETag removed.

Priority 4 — Medium

Finding: SPF misconfiguration includes internal .local host.

Evidence: DNS TXT: include:mme-srv-dc1.mme.local.

Mitigation: Remove .local include; ensure SPF includes only public authorized senders; test with SPF validator.

Validation: dig txt itsecgames.com shows corrected SPF.

Priority 5 — Low → Medium

Finding: Exposed default Apache files, server banner and possible Drupal header on a path.

Evidence: Nikto: /icons/README: Apache default file found. and Drupal 7 was identified via the x-generator header under /wwwitsecgamescom.war. Server: Apache header present.

Mitigation: Remove default files, hide server headers, remove stale or dev artifacts, and investigate any unexpected Drupal content.

Validation: curl -I and nikto should no longer show these items.

Priority 6 — Low

Finding: DNS not signed with DNSSEC.

Evidence: WHOIS shows DNSSEC: unsigned.

Mitigation: Enable DNSSEC with registrar and verify keys.

Validation: dig +dnssec or verifying DNSSEC presence on public tools.

Suggested remediation plan (detailed, stepwise)

Immediate actions

Remove bWAPP from the public Internet or hide it behind a VPN. (High priority: take immediate action.)

Take the.local entry out of SPF.

Short-term (next 1–7 days)

Update the operating system and its packages (OpenSSH, Apache, PHP, MySQL).

Harden Apache by turning off unnecessary modules, turning off ServerTokens Prod, turning off ServerSignature, and setting FileETag None.

Include the security headers (Referrer-Policy, X-Frame-Options, X-Content-Type-Options, and CSP).

Clear the webroot of stale artifacts and default files.

Medium-term (1–4 weeks)

Perform thorough SSL/TLS testing (SSL Labs), fix weak ciphers, and turn on OCSP and HSTS stapling.

Put in place network-level controls, such as a firewall that only permits SSH from management IPs.

If public access must be maintained, use WAF rules to prevent common attack patterns against the training app.

Long-term

Utilize vulnerability scanning and central patch management according to a predetermined schedule.

Use alerting and monitoring (logging, EDR, SIEM) to find attempts at exploitation.

Deploy training apps in lab VPCs that are isolated from the internet and have their own networking if necessary.

Evidence appendix (attach to your submission)

Use these exact evidence snippets in your report (they are taken from your provided outputs; include the original raw files as attachments):

DNS / SPF (dig-any.txt):

```
itsecgames.com. 600 IN A 31.3.96.40
```

```
itsecgames.com. 3600 IN TXT "v=spf1 mx a include:spf.protection.outlook.com include:servers.mcsv.net include:mme-srv-dc1.mme.local -all"
```

WHOIS (whois.txt): registrar GoDaddy, DNSSEC: unsigned, expiry 2027-05-21.

Homepage (homepage_http.html):

<title>bWAPP, a buggy web application!</title> and link: ./downloads/vulnerabilities.txt (shows deliberate vulnerabilities).

Headers (headers_http.txt):

```
HTTP/1.1 200 OK
```

```
Server: Apache
```

```
ETag: "e43-5d7959bd3c800"
```

```
Content-Encoding: gzip
```

Nikto (nikto-report.txt) selected lines:

+ /: The anti-clickjacking X-Frame-Options header is not present.

+ /: The X-Content-Type-Options header is not set.

+ /: Server may leak inodes via ETags, header found with file /, inode: e43, size: 5d7959bd3c800, mtime: gzip.

+ /wwwitsecgamescom.war: Drupal 7 was identified via the x-generator header.

+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS .

+ /icons/README: Apache default file found.

Nmap (nmap-top.nmap) snippet:

```
22/tcp open  ssh      OpenSSH 6.7p1 (protocol 2.0)
```

```
80/tcp open  http      Apache httpd
```

```
443/tcp open  ssl/http  Apache httpd
```

Validation commands (copy/paste to re-check after remediation)

DNS/SPF

```
dig txt itsecgames.com +short
```

Headers

```
curl -sI http://www.itsecgames.com/ | sed -n '1,200p'
```

```
curl -sI https://www.itsecgames.com/ | sed -n '1,200p'
```

SSL

run SSL Labs via web; local:

```
openssl s_client -connect www.itsecgames.com:443 -servername www.itsecgames.com </dev/null 2>/dev/null | sed -n '1,200p'
```

Nikto (if permitted to scan again)

```
nikto -h http://www.itsecgames.com -o nikto-validate.txt
```

Nmap (check SSH restriction)

```
nmap -p 22 --script ssh2-enum-algos 31.3.96.40
```


Methodology

This assessment was conducted using a combination of passive and light active reconnaissance techniques. No exploitation was attempted. The following tools and versions were used:

- dig / whois (for DNS enumeration)
- curl 7.x (for HTTP headers and content retrieval)
- whatweb (for technology fingerprinting)
- openssl 3.x (for TLS/SSL certificate checks)
- nikto v2.5.0 (for web server misconfiguration/vulnerability scan)
- nmap 7.94 (for service and version discovery)
- crt.sh (for certificate transparency / subdomain enumeration)

Scan dates: 26–27 September 2025 (UTC).

Scope: Limited to <http://www.itsecgames.com> and its associated services. Scans were restricted to non-intrusive reconnaissance. No exploitation was performed.

CVE Mapping for Detected Versions

During the scan, version information was disclosed for certain services. These versions are known to have associated CVEs which increase risk if unpatched. The following mappings were identified:

- OpenSSH 6.7p1:
 - CVE-2016-0777: Information leak via roaming feature.
 - CVE-2016-0778: Possible buffer overflow in certain configurations.Reference: <https://nvd.nist.gov/vuln/detail/CVE-2016-0777>

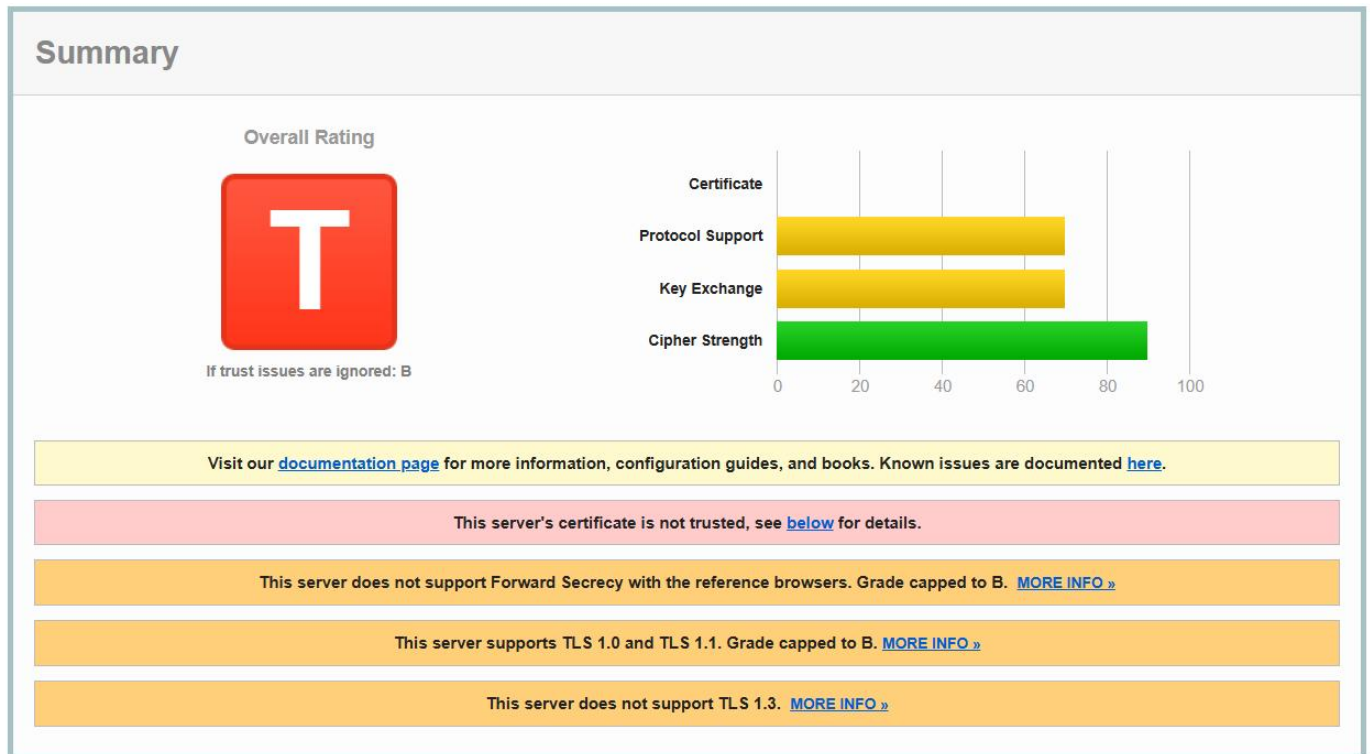
- Drupal 7 (detected via header):
 - CVE-2018-7600 (a.k.a. "Drupalgeddon 2"): Remote code execution in Drupal 7.x.Reference: <https://nvd.nist.gov/vuln/detail/CVE-2018-7600>

These findings highlight the importance of updating or restricting services to mitigate exposure to known vulnerabilities.

SSL Labs Test Evidence

An SSL Labs test was conducted against <https://www.itsecgames.com/>.

Placeholder:[SSL Server Test: www.itsecgames.com \(Powered by Qualys SSL Labs\)](#)



Sign-Off

Prepared by:Nihar Mehta

Date: 2025-09-27

Limitations: This report contains passive reconnaissance and light active discovery where authorized. No exploitation attempts were made. The findings are based on the state of the system at the time of scanning.